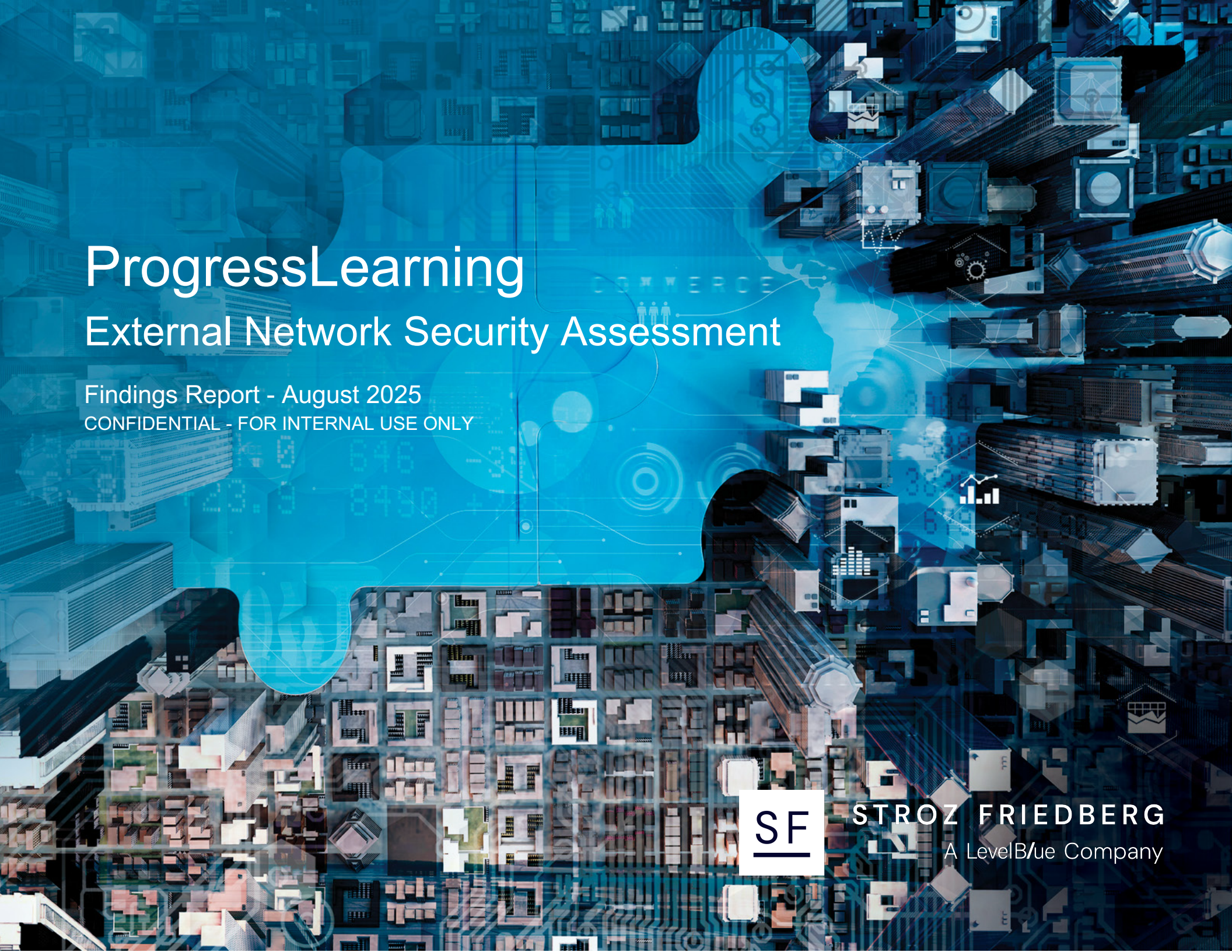




# ProgressLearning

## External Network Security Assessment

Findings Report - August 2025  
CONFIDENTIAL - FOR INTERNAL USE ONLY



STROZ FRIEDBERG  
A LevelBlue Company



# Table of Contents

|                                                                            |           |
|----------------------------------------------------------------------------|-----------|
| <b>Document Version Control .....</b>                                      | <b>3</b>  |
| <b>Project Summary .....</b>                                               | <b>4</b>  |
| Introduction .....                                                         | 4         |
| Approach and Scope .....                                                   | 4         |
| Target Network Environment .....                                           | 4         |
| Post-Assessment Clean-Up .....                                             | 5         |
| Testing Notes .....                                                        | 5         |
| <b>Severity Levels.....</b>                                                | <b>6</b>  |
| <b>Major Findings by Severity Level .....</b>                              | <b>7</b>  |
| <b>Itemized Issue Listing.....</b>                                         | <b>8</b>  |
| <b>Exhibit A: Post-Assessment Clean-Up .....</b>                           | <b>39</b> |
| <b>Appendix A: Stroz Friedberg's Penetration Testing Services .....</b>    | <b>40</b> |
| <b>Appendix B: Stroz Friedberg's Cyber Defense Training Platform .....</b> | <b>41</b> |
| <b>Appendix C: Vulnerability Management with CyberScan .....</b>           | <b>42</b> |

This document and any attachments may contain information that is confidential or protected by privilege from disclosure. It is intended solely for use by ProgressLearning, not intended to be relied upon by any third parties, and not to be disclosed to third parties without the express written consent of Stroz Friedberg, LLC. If you have reason to believe you are not the intended recipient, please immediately notify the sender by e-mail or by telephone, then destroy all copies of this document, including any printed copies.



# Document Version Control

| Date        | Author             | Description                         |
|-------------|--------------------|-------------------------------------|
| 08/18/20225 | Christopher Zavala | Report delivery to ProgressLearning |



# Project Summary

## Introduction

Stroz Friedberg was engaged by ProgressLearning in July 2025 to perform a four-day time-boxed external network security assessment of the Progress Learning external network environment. This report outlines the project scope, work performed, testing results, and recommendations to address the issues that were identified during the assessment.

## Approach and Scope

The security of the environment was assessed from the perspective of an unauthenticated attacker. Testing of the ProgressLearning external network was performed on the production environment over the Internet from the Stroz Friedberg office in New York, NY.

The scope of this security assessment was to perform dynamic network security testing to gauge the threat of external attackers gaining unauthorized access to ProgressLearning infrastructure and/or data. All Stroz Friedberg penetration testing follows the "Stroz Friedberg Penetration Testing Methodology", which consists of the following core phases:

- Phase 1: Target Company & Director / Employee Reconnaissance (Optional): Research and profiling are performed on ProgressLearning, its subsidiaries, and key identified personnel. All harvested data that is deemed sensitive, or could help remote attackers compromise corporate resources, is documented.
- Phase 2: Network Discovery & Estate Footprint Definition: Data stores such as DNS and WHOIS records are queried to obtain a list of network systems being used by ProgressLearning and its wholly owned subsidiaries. As network ranges are identified, preliminary port scans are performed to identify live systems.
- Phase 3: Vulnerability Scanning & Confirmation: A combination of remote automated scanning and manual testing is used to identify vulnerabilities that could potentially be used to compromise or gain access to in-scope systems. The results are manually validated by a Stroz Friedberg security engineer to ensure that no false positive results are reported.
- Phase 4: Vulnerability Exploitation and Network Penetration: Selected systems are then targeted for manual exploitation in a controlled and measured approach to gain perimeter system access. Compromised external facing systems are then used to pivot further into available corporate networks and to target additional hosts. The results of this phase are summarized in the 'Itemized Issue Listing' section of this report.

## Target Network Environment

The following web environments were included within the scope of testing.

- |                                   |                                      |                                    |
|-----------------------------------|--------------------------------------|------------------------------------|
| ▪ app.progresslearning.com        | ▪ content-api.progresslearning.com   | ▪ help.progresslearning.com        |
| ▪ app-api.progresslearning.com    | ▪ content.pendo.progresslearning.com | ▪ maintenance.progresslearning.com |
| ▪ academics.progresslearning.com  | ▪ data.pendo.progresslearning.com    | ▪ vpn.progresslearning.com         |
| ▪ apigateway.progresslearning.com | ▪ demo.progresslearning.com          | ▪ media.progresslearning.com       |
| ▪ assets.progresslearning.com     | ▪ docs.progresslearning.com          | ▪ media.educationgalaxy.com        |
| ▪ auth.progresslearning.com       | ▪ emailing.progresslearning.com      | ▪ meet.progresslearning.com        |
| ▪ blog.progresslearning.com       | ▪ healthcheck.progresslearning.com   | ▪ progresslearning.com             |



- salesforce-api.progresslearning.com
- shop.progresslearning.com
- smart.progresslearning.com
- staff.progresslearning.com

## Post-Assessment Clean-Up

Please see the section titled Exhibit A: Post-Assessment Clean-Up for the most relevant and notable activities to aid ProgressLearning's internal teams during their post-assessment clean-up procedures.

## Testing Notes

Stroz Friedberg's ability to thoroughly test this application was limited due to the following:

- Despite being allow-listed, testers still ran into issues with CloudFront and Cloudflare restricting parts of the environment, making network scanning more difficult. This was discussed with the client and troubleshooting occurred, allowing Stroz to confirm allow-listing occurred, but the exact cause was not found.



# Severity Levels

Issues in this report are grouped into severity levels based on the technical risk presented by each item. Severity levels are ranked Critical, High, Medium, Low, or Informational based on perceived overall threat.

| Severity Level       | Description                                                                                                                                                                                                                                                                                                                                       | Remediation Timeframe                                                                                                                                                                                                                                                 |
|----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>CRITICAL</b>      | Remotely exploitable issue, which can directly be used to compromise the server, access sensitive application functionality, or obtain confidential data. This includes impersonation of application accounts and unauthorized administrative host/application access. Typically, the exposure is easily identified, and exploitation is trivial. | Items should be addressed immediately. For items that cannot be addressed immediately, a temporary solution should be implemented to prevent exploitation. Items that are not rectified should be documented according to risk-acceptance policies.                   |
| <b>HIGH</b>          | Exploitable issue that could result in server compromise, access to sensitive application functionality, or disclosure of confidential data. Successful exploitation may require either user-level access to system/application or exploits may not be publicly available.                                                                        | Items should be addressed as soon as possible or within one month. For cases where this is not feasible, a temporary solution should be implemented to prevent exploitation. Items that are not rectified should be documented according to risk-acceptance policies. |
| <b>MEDIUM</b>        | Issue is typically leveraged in conjunction with one or more security issues to compromise the server, application, data, or user accounts. This level is also used to classify failures in error handling, auditing, or logging.                                                                                                                 | Items should be addressed as soon as possible or within two months. Consider documenting items that are not rectified in accordance with risk-acceptance policies.                                                                                                    |
| <b>LOW</b>           | Results from general information leakage about the application, network, server, user accounts, or is inconsistent with security best practices and guidelines.                                                                                                                                                                                   | Items can be addressed at the discretion of system owners. Depending on company policy, documentation may not be required for risk-acceptance.                                                                                                                        |
| <b>INFORMATIONAL</b> | Items that may be of interest or do not conform with best practices but are not considered vulnerabilities.                                                                                                                                                                                                                                       | Items might lead to future issues but are not an imminent threat and do not have to be addressed.                                                                                                                                                                     |



# Major Findings by Severity Level

The following is a list of all unique major findings discovered during the engagement. The items are categorized below based on the Stroz Friedberg Severity Level assigned to each issue.

| Issue Title                                                   | Critical | High     | Medium   | Low      | Informational |
|---------------------------------------------------------------|----------|----------|----------|----------|---------------|
| 1. WordPress Remote Username Enumeration Vulnerability        | -        | -        | 1        | 3        | -             |
| 2. Client-Side JavaScript Contains Sensitive Information      | -        | -        | 2        | -        | -             |
| 3. Vulnerable Outdated Software Components                    | -        | -        | 1        | -        | 1             |
| 4. Denial of Service Condition Possible                       | -        | -        | 1        | -        | -             |
| 5. WordPress XML-RPC Vulnerable Configuration                 | -        | -        | 1        | -        | -             |
| 6. Sensitive Web Server Files Accessible to Users             | -        | -        | -        | 1        | 2             |
| 7. Source Map Enabled on JavaScript Deployed with Webpack     | -        | -        | -        | 1        | -             |
| 8. Web Server Reveals Internal Host IP Address                | -        | -        | -        | 1        | -             |
| 9. Insecure TLS/SSL Configuration                             | -        | -        | -        | -        | 3             |
| 10. HTTP Security Response Header Misconfiguration            | -        | -        | -        | -        | 1             |
| 11. Potentially Unnecessary Network Services Exposed Remotely | -        | -        | -        | -        | 1             |
| <b>Total</b>                                                  | <b>0</b> | <b>0</b> | <b>6</b> | <b>6</b> | <b>8</b>      |



# Itemized Issue Listing

This section of the report includes a detailed listing of each specific issue identified during the engagement. For reporting purposes, individual issues that are similar in nature have been grouped together and assigned a major finding number. The figure below outlines page layout used on the pages within this section of the report and has been included for reference.

## Sample Itemized Issue Listing Page

For each of the major vulnerabilities identified during the assessment, the following five items are presented. The figure on the right highlights the location of each data element within a typical Itemized Issue Listing page.

1. Major finding number and vulnerability title
2. Icon indicating the severity level associated with the most critical item within this major finding
3. An overview and description of the issue
4. Suggested remediation procedures to address or mitigate the vulnerability
5. A detailed listing of each issue. Each item within the listing includes the following information:
  - Unique ID number for the specific item
  - Status of the item (Open / Closed / Mitigated)
  - Severity level for the item
  - Subject name (Filename, URL, Server, etc.)
  - Individual notes pertaining to the item

The diagram illustrates the layout of a sample itemized issue listing page. It features a header with a major finding number (1) and a severity level icon (2). The main content area is divided into sections: an overview (3), a remediation procedure (4), and an issue listing (5). The issue listing section includes a table with columns for ID, Status, Severity, and Subject, and a description of the issue. A note at the bottom states: 'Note: GDS found the TradeHack application susceptible to this attack within each blog post comment section.'

**1. Cross-Site Scripting (XSS)** HIGH

**Overview**

The TradeHack application is vulnerable to Cross-Site Scripting (XSS) attacks. Attackers can exploit this issue to inject arbitrary client-side code (e.g., JavaScript) within application parameters that will ultimately execute within the target user's web browser. XSS vulnerabilities are frequently exploited to steal cookies associated with the vulnerable domain, gain unauthorized access to users' authenticated sessions, alter or deface the content of the vulnerable web page, redirect users to phishing or malicious websites, or compromise users' web browsers.

**Remediation Procedure**

All data elements rendered within response content must be properly encoded to ensure the data is not interpreted as markup code by users' web browsers. If content is processed by server-side logic, and depending on where within the response the data is rendered, one of the following encoding methods should be used:

- **HTML:** HTML encoding should be used to escape all rendered output. For example, script tags are escaped by replacing the < and > characters with &lt; and &gt;.
- **JavaScript:** Data rendered within JavaScript code can be encoded into the format \xDD where DD is the hexadecimal value of the ASCII character. This ensures that encoded characters are treated literally by the browser, rather than interpreted as meta characters.
- **URL:** Data rendered within a URL should be URL encoded into the format %DD, where DD is the hexadecimal value of the ASCII character.
- **HTML Attributes:** When rendering data in HTML attributes, ensure that the attribute is properly quoted and that any quotes within the data value are encoded. For example, double quotes " can be encoded as &quot;.

**Issue Listing**

The following item is included under this major finding:

| ID  | Status | Severity | Subject                                                            |
|-----|--------|----------|--------------------------------------------------------------------|
| 1.1 | Open   | High     | http://75d5e23c-6d2d-4174-bd85-65aad63edabc.gdsdemo.com/blog/post/ |

**Description**

The identified endpoint is used to add comments to blog posts. This parameter is vulnerable to persistent Cross-Site Scripting. The application accepts the \_CALLBACKPARAM without input validation. The comment output is not properly output encoded on user comments. Because of this, the reflected JavaScript will execute on the page within the browser.

*Note: GDS found the TradeHack application susceptible to this attack within each blog post comment section.*



# 1. WordPress Remote Username Enumeration Vulnerability

MEDIUM

## Overview

ProgressLearning does not implement sufficient WordPress protections to prevent attackers from enumerating valid WordPress usernames.

When WordPress is misconfigured, attackers can remotely enumerate WordPress usernames via the following techniques:

- By force browsing to the RSS feed endpoint to retrieve a list of WordPress user details, including their usernames. For example, the endpoint `"/feed/rdf"` can be accessed without authentication.
- By force browsing to WordPress REST APIs to retrieve a list of WordPress user details, including their usernames. For example, the endpoints `"/wp-json/wp/v2/users/"` and `"/wp-json/?rest_route=/wp/v2/users/"` can be accessed without authentication.
- By enumerating the ID value of the "author" parameter. For example, the endpoint `"/?author=1"` can be enumerated to retrieve all posts from the user that is associated with an ID value of "1". As a result of this enumeration, the user's username will also be revealed.

After retrieving valid WordPress usernames, an attacker can use them to perform further attacks (e.g., brute-force attacks on login pages).

## Remediation Procedure

To prevent disclosure of WordPress usernames, implement the following recommended countermeasures:

1. Add the following code snippet to the root `".htaccess"` file.

Sample Code Snippet:

```
<IfModule mod_rewrite.c>
RewriteCond %{QUERY_STRING} ^author=([0-9]*)
RewriteRule .* http://site.com/? [L,R=302]
</IfModule>
```

2. To prevent unauthenticated access to the REST API `"/wp-json/wp/v2/users"` endpoint, enable authentication for all REST API requests by adding `"is_user_logged_in"` check to the `"rest_authentication_errors"` filter.

For more details on enabling authentication, reference to the following resource:

- <https://developer.wordpress.org/rest-api/frequently-asked-questions/#require-authentication-for-all-requests>

3. Utilize WordPress's "Stop User Enumeration" security plug-in.

For more details on the "Stop User Enumeration" security plug-in, reference to the following resource:

- <https://wordpress.org/plugins/stop-user-enumeration/>

4. To prevent user enumeration from the RSS feed endpoint, either disable feeds entirely or ensure that usernames are not revealed in the feeds.

## Issue Listing

The following items are included under this major finding:



| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | Status | Severity | Subject                           |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|-----------------------------------|
| 1.1                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Open   | Medium   | WordPress REST APIs [2 instances] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |        |          |                                   |
| WordPress REST API endpoints are externally accessible to unauthenticated users, revealing WordPress usernames and some profile information.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |        |          |                                   |
| <b>Reproduction Request:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |        |          |                                   |
| <pre>GET /wp-json/wp/v2/users/ HTTP/2 Host: educationgalaxy.com [...]</pre>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |        |          |                                   |
| <b>Reproduction Response:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |        |          |                                   |
| <pre>HTTP/2 200 OK Date: Fri, 01 Aug 2025 18:47:32 GMT Content-Type: application/json; charset=UTF-8 [...]</pre> <pre>[{"id":1,"name":"admin","url":"","description":"","link":"https://educationgalaxy.com/author/admin/","slug":"admin","avatar_urls":{"24":"https://secure.gravatar.com/avatar/6c5d0f54464953c839fbf2779bc397646726cf15441003bd753b605fadc117ca?s=24&amp;d=mm&amp;r=g","48":"https://secure.gravatar.com/avatar/6c5d0f54464953c839fbf2779bc397646726cf15441003bd753b605fadc117ca?s=96&amp;d=mm&amp;r=g"},"meta":[],"acf":[],"elementor_introduction":"","_links":{"self":{"href":"https://educationgalaxy.com/wp-json/wp/v2/users/1"},"targetHints":{"allow":["GET"]}}},"collection":[{"href":"https://educationgalaxy.com/wp-json/wp/v2/users/"}]},{id:6,"name":"Pooja Upwork","url":"","description":"","link":"https://educationgalaxy.com/author/pooja/","slug":"pooja","avatar_urls":{"24":"https://secure.gravatar.com/avatar/c298c1787dda7c7728c68594c54a3ca2d9948cd1ab82f0dc860919e431f80bef?s=24&amp;d=mm&amp;r=g","48":"https://secure.gravatar.com/avatar/c298c1787dda7c7728c68594c54a3ca2d9948cd1ab82f0dc860919e431f80bef?s=96&amp;d=mm&amp;r=g"},"meta":[],"acf":[],"elementor_introduction":{"ai-get-started-announcement":true,"yoast-introduction-editor-v2":true,"globals_introduction":true},"_links":{"self":{"href":"https://educationgalaxy.com/wp-json/wp/v2/users/6"},"targetHints":{"allow":["GET"]}}},"collection":[{"href":"https://educationgalaxy.com/wp-json/wp/v2/users/"}]},{id:8,"name":"Ryan Mason","url":"","description":"","link":"https://educationgalaxy.com/author/ryan/","slug":"ryan","avatar_urls":{"24":"https://secure.gravatar.com/avatar/7cded48094c6c0de6d8e24b0fd55f4c6ee249d9648a870521050e27a43c9f58f?s=24&amp;d=mm&amp;r=g","48":"https://secure.gravatar.com/avatar/7cded48094c6c0de6d8e24b0fd55f4c6ee249d9648a870521050e27a43c9f58f?s=96&amp;d=mm&amp;r=g"},"meta":{"acf":{"ai-get-started-announcement":true,"yoast-introduction-editor-v2":true},"_links":{"self":{"href":"https://educationgalaxy.com/wp-json/wp/v2/users/8"},"targetHints":{"allow":["GET"]}}},"collection":[{"href":"https://educationgalaxy.com/wp-json/wp/v2/users/"}]}]</pre> |        |          |                                   |
| <b>Identified Instances (2):</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |        |          |                                   |
| <ul style="list-style-type: none"> <li>educationgalaxy.com</li> <li>progresslearning.com</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |        |          |                                   |

| ID                                                                                                            | Status | Severity | Subject                          |
|---------------------------------------------------------------------------------------------------------------|--------|----------|----------------------------------|
| 1.2                                                                                                           | Open   | Low      | RSS Feed Endpoints [2 instances] |
| <b>Description</b>                                                                                            |        |          |                                  |
| RSS feed endpoints are externally accessible to unauthenticated users, revealing WordPress usernames.         |        |          |                                  |
| <b>Reproduction Steps:</b>                                                                                    |        |          |                                  |
| 1. In a web browser, go to one of the identified instances, with the addition of /feed/rdf to the end of URL. |        |          |                                  |

| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Status | Severity | Subject                          |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|----------------------------------|
| 1.2                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          | Open   | Low      | RSS Feed Endpoints [2 instances] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |        |          |                                  |
| 2. Observe the contents in the web page, specifically the usernames. If automatically downloaded instead, observe the file contents in "download.rdf".                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |        |          |                                  |
| <b>File contents of download.rdf:</b> <pre>&lt;rdf:RDF&gt; &lt;channel rdf:about="https://educationgalaxy.com/"&gt; &lt;title&gt;Educationgalaxy&lt;/title&gt; &lt;link&gt;https://educationgalaxy.com/&lt;/link&gt; &lt;description/&gt; &lt;dc:date&gt;2018-10-16T13:44:16Z &lt;/dc:date&gt; &lt;sy:updatePeriod&gt; hourly &lt;/sy:updatePeriod&gt; &lt;sy:updateFrequency&gt; 1 &lt;/sy:updateFrequency&gt; &lt;sy:updateBase&gt;2000-01-01T12:00+00:00&lt;/sy:updateBase&gt; [...]</pre> <pre>&lt;item rdf:about="https://educationgalaxy.com/adaptive-intervention/even-the-questions-are-engaging/"&gt; &lt;title&gt;Even The Questions Are Engaging!&lt;/title&gt; &lt;link&gt; https://educationgalaxy.com/adaptive-intervention/even-the-questions-are-engaging/ &lt;/link&gt; &lt;dc:creator&gt;admin&lt;/dc:creator&gt; &lt;dc:date&gt;2018-08-27T12:14:43Z&lt;/dc:date&gt; &lt;dc:subject&gt;Adaptive Intervention&lt;/dc:subject&gt; &lt;items&gt; [...]</pre> |        |          |                                  |
| <b>Identified Instances (2):</b> <ul style="list-style-type: none"> <li>educationgalaxy.com</li> <li>progresslearning.com</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |        |          |                                  |

| ID                                                                                                                                                                                                                         | Status | Severity | Subject                         |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|---------------------------------|
| 1.3                                                                                                                                                                                                                        | Open   | Low      | "Author" Parameter [1 instance] |
| <b>Description</b>                                                                                                                                                                                                         |        |          |                                 |
| The "author" parameter can be used to enumerate WordPress users by altering the numerical value.                                                                                                                           |        |          |                                 |
| <i>Note: This finding was previously reported as "3.1 WordPress Remote Username Enumeration Vulnerability" in the report titled "AON-6433 ProgressLearning External Network Security Assessment Report February_2024".</i> |        |          |                                 |
| <b>Reproduction Request:</b> <pre>GET /?author=1 HTTP/2 Host: educationgalaxy.com [...]</pre>                                                                                                                              |        |          |                                 |

| ID                                                                                                                                                                                                                                                                     | Status | Severity | Subject                         |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|---------------------------------|
| 1.3                                                                                                                                                                                                                                                                    | Open   | Low      | "Author" Parameter [1 instance] |
| <b>Description</b>                                                                                                                                                                                                                                                     |        |          |                                 |
| <b>Reproduction Response:</b><br>HTTP/2 301 Moved Permanently<br>Date: Fri, 01 Aug 2025 18:53:15 GMT<br>Content-Type: text/html; charset=UTF-8<br>Location: <a href="https://educationgalaxy.com/author/admin/">https://educationgalaxy.com/author/admin/</a><br>[...] |        |          |                                 |
| <b>Identified Instance:</b> <ul style="list-style-type: none"> <li>educationgalaxy.com</li> </ul>                                                                                                                                                                      |        |          |                                 |

| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | Status | Severity | Subject                         |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|---------------------------------|
| 1.4                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Open   | Low      | author-sitemap.xml [1 instance] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |        |          |                                 |
| Yeast SEO generates an xml sitemap containing links to authors by their usernames. This page is meant for consumption by search engines, but can assist an attacker by revealing WordPress usernames.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |        |          |                                 |
| <b>Reproduction Request:</b><br>GET /author-sitemap.xml HTTP/1.1<br>Host: educationgalaxy.com<br>[...]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |        |          |                                 |
| <b>Reproduction Response:</b><br>HTTP/2 200 OK<br>Date: Fri, 01 Aug 2025 18:36:22 GMT<br>Content-Type: text/xml; charset=UTF-8<br>[...] <pre> &lt;?xml version="1.0" encoding="UTF-8"?&gt;&lt;?xml-stylesheet type="text/xsl" href="//educationgalaxy.com/wp-content/plugins/wordpress-seo/css/main-sitemap.xsl"?&gt; &lt;urlset xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:image="http://www.google.com/schemas/sitemap-image/1.1" xsi:schemaLocation="http://www.sitemaps.org/schemas/sitemap/0.9 http://www.sitemaps.org/schemas/sitemap/0.9/sitemap.xsd http://www.google.com/schemas/sitemap-image/1.1 http://www.google.com/schemas/sitemap-image/1.1/sitemap-image.xsd" xmlns="http://www.sitemaps.org/schemas/sitemap/0.9"&gt;   &lt;url&gt;     &lt;loc&gt;<a href="https://educationgalaxy.com/author/admin/">https://educationgalaxy.com/author/admin/</a>&lt;/loc&gt;     &lt;lastmod&gt;2022-10-03T13:59:06+00:00&lt;/lastmod&gt;   &lt;/url&gt; &lt;/urlset&gt; &lt;!-- XML Sitemap generated by Yeast SEO --&gt; </pre> |        |          |                                 |
| <b>Identified Instance:</b> <ul style="list-style-type: none"> <li>educationgalaxy.com</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |        |          |                                 |

## 2. Client-Side JavaScript Contains Sensitive Information

MEDIUM

### Overview

Applications on the Progress Learning external network serve JavaScript code containing sensitive information that may be useful to an attacker. Modern web applications often offload code relating to application functionality for performance reasons — such as in single-page applications (SPAs) — however, this should not be done in a way that compromises the security of the application.

Examples of sensitive information that should not be bundled into client-side JavaScript include:

- **API Keys:** The bundled JavaScript client includes API keys that should not be public. An example can be AWS keys or GitHub tokens.
- **Hardcoded Credentials:** The bundled JavaScript client includes credentials. This should not be hardcoded for the JavaScript client, nor should it be exposed.
- **Extraneous API Functionality:** Details of server-side API calls should not be disclosed to standard application users. This increases the likelihood of a user manipulating unintended server-side components and functionality.

### Remediation Procedure

Ensure that developers review the identified issues and refactor their deployment process to ensure that:

- API keys are limited to ad-trackers or intended to be public. In general, API keys should be used server-side to fetch resources on behalf of the client.
- Remove any hard coded credentials and rotate when needed.

By taking these steps, developers can reduce the overall attack surface of their application.

If sensitive information such as API keys have been leaked, ensure that these tokens are rotated after they have been removed.

### Issue Listing

The following items are included under this major finding:

| ID                                                                                                                                                                                                                                                                    | Status | Severity | Subject                                       |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|-----------------------------------------------|
| 2.1                                                                                                                                                                                                                                                                   | Open   | Medium   | Basic Authorization Credentials [2 instances] |
| <b>Description</b>                                                                                                                                                                                                                                                    |        |          |                                               |
| Stroz Friedberg discovered hardcoded credentials in the Base64 encoded format within multiple JavaScript files. The severity of this finding is rated medium as Stroz Friedberg was unable to determine the use case for these credentials during the testing period. |        |          |                                               |
| <i>Note: One instance was previously reported as "#1.2 Client-Side JavaScript Contains Sensitive Information" in the report titled "AON-6433 ProgressLearning External Network Security Assessment Report February_2024".</i>                                         |        |          |                                               |
| <b>Reproduction Request:</b>                                                                                                                                                                                                                                          |        |          |                                               |
| GET /static/js/main.a6064968.js HTTP/2<br>Host: app.progresslearning.com                                                                                                                                                                                              |        |          |                                               |



| ID                                                                                                                                                                                                                                                                                                                                                          | Status | Severity | Subject                                       |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|-----------------------------------------------|
| 2.1                                                                                                                                                                                                                                                                                                                                                         | Open   | Medium   | Basic Authorization Credentials [2 instances] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                          |        |          |                                               |
| [...]                                                                                                                                                                                                                                                                                                                                                       |        |          |                                               |
| <b>Reproduction Response:</b>                                                                                                                                                                                                                                                                                                                               |        |          |                                               |
| HTTP/2 200 OK<br>Date: Fri, 01 Aug 2025 12:24:50 GMT<br>Content-Type: application/javascript<br>Last-Modified: Wed, 30 Jul 2025 18:29:03 GMT<br>[...]<br>headers:{"Access-Control-Allow-Origin":"*", <b>Authorization:"Basic ZWdDbG1bnQ6OTZlYjMxMzYtYmE5MS00Yjc0LTgzMmEtMGRiMTV1bjU0ZTM4"</b> ,"Content-Type":"application/x-www-form-urlencoded"}<br>[...] |        |          |                                               |
| <b>Identified Instances (2):</b>                                                                                                                                                                                                                                                                                                                            |        |          |                                               |
| <ul style="list-style-type: none"> <li>https://academics.progresslearning.com/static/js/530.16bc88e0.chunk.js</li> <li>https://app.progresslearning.com/static/js/main.a6064968.js (previously reported)</li> </ul>                                                                                                                                         |        |          |                                               |

| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Status | Severity | Subject                |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|------------------------|
| 2.2                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | Open   | Medium   | API Keys [2 instances] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |        |          |                        |
| Stroz Friedberg discovered hardcoded API keys within multiple JavaScript files. An attacker may abuse these keys to issue arbitrary API requests to the given platform.<br><br><i>Note: One instance was previously reported as "#1.2 Client-Side JavaScript Contains Sensitive Information" in the report titled "AON-6433 ProgressLearning External Network Security Assessment Report February_2024".</i>                                                                                                                                                                                                                                                        |        |          |                        |
| <b>Reproduction Request:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |        |          |                        |
| GET /static/js/main.7c7b47ca.js HTTP/2<br>Host: academics.progresslearning.com<br>[...]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |        |          |                        |
| <b>Reproduction Response:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |        |          |                        |
| HTTP/2 200 OK<br>Date: Thu, 31 Jul 2025 20:26:30 GMT<br>Content-Type: application/javascript<br>Last-Modified: Wed, 23 Jul 2025 19:23:44 GMT<br>[...]<br>if({NODE_ENV:"production",PUBLIC_URL:"",WDS_SOCKET_HOST:void 0,WDS_SOCKET_PATH:void 0,WDS_SOCKET_PORT:void 0,FAST_REFRESH:!0,REACT_APP_BASEURL:"https://apigateway.progresslearning.com",REACT_APP_BASEURL_AUTH:"https://auth.progresslearning.com",REACT_APP_BASEURL_MEDIA:"https://media.progresslearning.com",REACT_APP_CONSUMER_KEY:"af107ctuQAY31DX0", <b>REACT_APP_LEARNOSITY_SECRET_KEY:"B1Ks1Ys52YQew13B6qoxhUvn121FpcF9W7Ssk684"</b> ,REACT_APP_PP_Dev_URL:"academics-dev.progresslearning.com"}) |        |          |                        |

| ID                                                                                                                                                                                                                                              | Status | Severity | Subject                |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|------------------------|
| 2.2                                                                                                                                                                                                                                             | Open   | Medium   | API Keys [2 instances] |
| <b>Description</b>                                                                                                                                                                                                                              |        |          |                        |
| <b>Identified Instances (2):</b> <ul style="list-style-type: none"> <li>https://academics.progresslearning.com/static/js/main.7c7b47ca.js</li> <li>https://app.progresslearning.com/static/js/main.a6064968.js (previously reported)</li> </ul> |        |          |                        |



## MEDIUM

Stroz Friedberg identified software components that are no longer supported by the vendor and are vulnerable to known security exposures. Software that is no longer supported will not receive patches for new security vulnerabilities. As a result, they are likely to present a significant vulnerability to their environment and increase the risk of system compromise or unauthorized data disclosure.

Ensure the software components listed below are updated and patched. In general, all software should be upgraded to the most recent and stable version. Additionally, system management procedures should mandate software upgrades in the event that support for an operating system or software component is discontinued.

The following items are included under this major finding:

| ID  | Status | Severity | Subject                        |
|-----|--------|----------|--------------------------------|
| 3.1 | Open   | Medium   | Identity Server 4 [1 instance] |

**Description**

Identity Server 4 on auth.progresslearning.com is using an end-of-life version that is vulnerable to arbitrary URL redirection attacks. It should be updated to version 7.2.4, the latest at the time of writing.

**Reproduction Request:**

```
GET /home/error?errorId=CfDJ8Le80xzuC5tPmetS9rHDsP5lB9bXhKHojGohEzg1VSWrHD9NpVCB5-
QVRjYnVPhqPDwmqV1xM0qIwdjE1e7ubfijV5Q7isjEm8BWRFBuPDFVthTsyda_0XhLsUpe7pyuagiesPy-wdPD0SPHk1KYepxph_zc9m7I6Y3F2mrdXxV_cvOy7NVb01z1Uydq-
1KglkGrrjDt8M6YFU7DU2QVf_gzktP3vbrQALo6kFuguvFLId_wm233QgFIIElCeQPKerRdZMQW2RF6NoZrg40nV3nerch9_KL6-
TKCIUQAV66eA23W6AR3rSduARJhv56wE_MMfc0IjE_jwHk9dIIPtStLrJt9DLm53e_24Y9BKYMfx1KdHim41RGJfkn6DyVqMWSFwib3MScQ6a4E_MpCtIH-EpEnxu1aKEffLCbJQBS HTTP/2
Host: auth.progresslearning.com
[...]
```

**Reproduction Response:**

```
HTTP/2 200 OK
Date: Fri, 01 Aug 2025 14:22:57 GMT
Content-Type: text/html; charset=utf-8
Server: cloudflare
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
[...]
```

```
<div class="nav-page">
  <nav class="navbar navbar-expand-lg navbar-dark bg-dark">

    <a href="/" class="navbar-brand">
      
        IdentityServer4
    </a>
```

| ID                                                                                                                                                                            | Status | Severity | Subject                        |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|--------------------------------|
| 3.1                                                                                                                                                                           | Open   | Medium   | Identity Server 4 [1 instance] |
| <b>Description</b>                                                                                                                                                            |        |          |                                |
| </nav><br></div><br>[...]                                                                                                                                                     |        |          |                                |
| <b>Resources:</b> <ul style="list-style-type: none"><li>https://nvd.nist.gov/vuln/detail/cve-2024-39694</li><li>https://github.com/DuendeSoftware/products/releases</li></ul> |        |          |                                |
| <b>Identified Instance:</b> <ul style="list-style-type: none"><li>auth.progresslearning.com</li></ul>                                                                         |        |          |                                |

| ID                                                                                                                                                                                                                                                                                                          | Status | Severity      | Subject                  |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|---------------|--------------------------|
| 3.2                                                                                                                                                                                                                                                                                                         | Open   | Informational | PHP v8.2.29 [1 instance] |
| <b>Description</b>                                                                                                                                                                                                                                                                                          |        |               |                          |
| The endpoint educationgalaxy.com uses PHP v8.2.29, an outdated version. It should be updated to version 8.4.11, the latest at the time of writing. The severity of this finding has been lowered as there are currently no known vulnerabilities.                                                           |        |               |                          |
| <b>Reproduction Request:</b><br>GET /phpinfo.php HTTP/2<br>Host: educationgalaxy.com<br>[..]                                                                                                                                                                                                                |        |               |                          |
| <b>Reproduction Response:</b><br>HTTP/2 200 OK<br>Date: Fri, 01 Aug 2025 17:50:20 GMT<br>Content-Type: text/html; charset=utf-8<br>Strict-Transport-Security: max-age=31536000<br>[...]<br><title>PHP 8.2.29 - phpinfo()</title><meta name="ROBOTS" content="NOINDEX,NOFOLLOW,NOARCHIVE" /></head><br>[...] |        |               |                          |
| <b>Resource:</b> <ul style="list-style-type: none"><li>https://www.php.net/downloads.php</li></ul>                                                                                                                                                                                                          |        |               |                          |
| <b>Identified Instance:</b> <ul style="list-style-type: none"><li>educationgalaxy.com</li></ul>                                                                                                                                                                                                             |        |               |                          |



## 4. Denial of Service Condition Possible

MEDIUM

### Overview

The educationgalaxy.com endpoint is vulnerable to a potential Denial of Service (DoS) condition vulnerability. DoS vulnerabilities typically exist due to a lack of validation on unexpected user-supplied inputs, improper error handling by the application, broken logic processing, insufficient resource management, vulnerable regular expressions, etc. As a result of exploiting these weaknesses, the application becomes either unresponsive or degrades in performance. An attacker who successfully exploits DoS vulnerabilities can purposely make the application and related services unavailable for other users.

In this specific instance, sending a large number of requests to wp-cron.php causes the application to become unresponsive or crash because it is a script that performs a scheduled tasks for the application. These tasks can use a large number of resources, therefore making the script a target for DoS attacks.

### Remediation Procedure

Investigate the identified DoS instances to determine the root cause of the issue. The development team can review the application and server logs to determine the approximate point in time when the application and associated services have failed to respond.

Depending on the root cause of the issue, appropriate steps for countermeasures should be taken accordingly. Typically, options for remediation may include one or more of the following:

- Implement input validation and sanitization of user-supplied inputs.
- Implement proper error handling.
- Implement a rate limiting mechanism to control the number of requests sent with the affected application component in quick succession.
- Limit the total request size permitted by the affected functionality/service.
- Fix any broken application logic in the code.
- Allocate resources in a way that will reduce the likelihood of exhaustion.
- Ensure regular expressions are not used in a way that can result in a Regular Expression Denial of Service (ReDoS).

### Issue Listing

The following item is included under this major finding:

| ID                                                                                                                                                           | Status | Severity | Subject                  |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|--------------------------|
| 4.1                                                                                                                                                          | Open   | Medium   | wp-cron.php [1 instance] |
| Description                                                                                                                                                  |        |          |                          |
| The endpoint educationgalaxy.com/wp-cron.php is externally accessible to unauthenticated users, making it potentially vulnerable to DoS attacks.             |        |          |                          |
| <b>Resource:</b> <ul style="list-style-type: none"><li>▪ <a href="https://hackerone.com/reports/1888723">https://hackerone.com/reports/1888723</a></li></ul> |        |          |                          |



| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | Status | Severity | Subject                  |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|--------------------------|
| 4.1                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Open   | Medium   | wp-cron.php [1 instance] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |        |          |                          |
| <b>Reproduction Request:</b><br><b>POST /wp-cron.php</b> HTTP/2<br>Host: educationgalaxy.com<br>[...]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |        |          |                          |
| <b>Reproduction Request:</b><br><b>HTTP/2 200 OK</b><br>Date: Fri, 01 Aug 2025 15:34:32 GMT<br>Content-Type: text/html; charset=utf-8<br>Strict-Transport-Security: max-age=31536000<br>Vary: Accept-Encoding<br>X-Hacker: Want root? Visit join.a8c.com and mention this header.<br>Host-Header: WordPress.com<br>Expires: Wed, 11 Jan 1984 05:00:00 GMT<br>Cache-Control: no-cache, must-revalidate, max-age=0<br>X-Ac: 23.jfk_atomic_dca BYPASS<br>Server-Timing: a8c-cdn, dc;desc=jfk, cache;desc=BYPASS;dur=21.0<br>Alt-Svc: h3=":443"; ma=86400<br>Cf-Cache-Status: DYNAMIC<br>Report-To:<br>{"endpoints":[{"url":"https://a.nel.cloudflare.com/report/v4?s=sBWJRS24Lzm6bj5AT3LP7RLEwjDYRRwWSgZJe1BHnFP4%2FYfcg1grCc8imUk8h10duTmWz0inqBBSL9WXI0n9PEOLLpKD4QDB1Q3jD8n1B9nZYi8VbRTiNe7CVk4rf1mboZXzTBn9"}],"group":"cf-nel","max_age":604800}<br>Nel: {"success_fraction":0,"report_to":"cf-nel","max_age":604800}<br>Server: cloudflare<br>Cf-Ray: 968666736d1242d1-EWR<br>Server-Timing:<br>cfl4;desc="?proto=TCP&rtt=51804&min_rtt=36261&rtt_var=22314&sent=6&recv=12&lost=0&retrans=0&sent_bytes=803&recv_bytes=1817&delivery_rate=59551&cwnd=253&unsent_bytes=0&cid=bb291ba84aa9495b&ts=126&x=0" |        |          |                          |
| <b>Identified Instance:</b> <ul style="list-style-type: none"> <li>educationgalaxy.com/wp-cron.php</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |        |          |                          |



## 5. WordPress XML-RPC Vulnerable Configuration

MEDIUM

### Overview

WordPress offers the functionality of receiving Remote Procedure Calls (RPC) but exposes sensitive methods that can be abused. By default, the XML-RPC functionality is enabled for WordPress versions 3.5 and higher, which allows instances to receive remote commands using XML over HTTP. Attackers can potentially abuse certain methods on this endpoint to perform malicious activities.

As an example, to obtain a list of enabled methods, an attacker can make the following request to the "system.listMethods" method:

```
POST /xmlrpc.php HTTP/1.1
Host: example.com
Content-Length: 135
<?xml version="1.0" encoding="utf-8"?>
<methodCall>
<methodName>system.listMethods</methodName>
<params></params>
</methodCall>
```

Some methods that pose a security risk are:

- *pingback.ping*: This method allows an attacker to initiate a pingback request to an arbitrary website, which can be exploited to perform distributed denial-of-service (DDoS) attacks.
- *wp.getUsersBlogs*: This method requires a username and password to retrieve a user's posts. Because usernames are easily enumerable, an attacker can attempt to brute force the corresponding password for each account.
- *wp.uploadFile*: This method can be used by an attacker with valid credentials and file upload permissions to upload arbitrary media files to the server, potentially leading to further exploitation.

### Remediation Procedure

XML-RPC has been superseded by the WordPress REST API. Any functionality using XML-RPC should be migrated to the REST API. For more information, refer to the official documentation.

- <https://developer.wordpress.org/rest-api/>

Disable XML-RPC using a *.htaccess* file as shown in the example below.

```
<Files xmlrpc.php>
order deny,allow
deny from all
allow from xxx.xxx.xxx.xxx
</Files>
```

Alternatively, use the "Disable XML-RPC" plugin.

- <https://wordpress.org/plugins/disable-xml-rpc/>



Issue Listing

The following item is included under this major finding:

| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | Status | Severity | Subject                  |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|--------------------------|
| 5.1                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Open   | Medium   | xmlrpc.php [2 instances] |
| Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |        |          |                          |
| Sensitive methods are exposed via xmlrpc.php on two endpoints.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |        |          |                          |
| Reproduction Request:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |        |          |                          |
| <pre>POST /xmlrpc.php HTTP/2 Host: educationgalaxy.com [...] Content-Length: 133  &lt;?xml version="1.0" encoding="utf-8"?&gt; &lt;methodCall&gt; &lt;methodName&gt;system.listMethods&lt;/methodName&gt; &lt;params&gt;&lt;/params&gt; &lt;/methodCall&gt;</pre>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |        |          |                          |
| Reproduction Response:                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |        |          |                          |
| <pre>HTTP/2 200 OK Date: Fri, 01 Aug 2025 14:46:22 GMT Content-Type: text/xml; charset=UTF-8 Strict-Transport-Security: max-age=31536000 Vary: Accept-Encoding [...] &lt;?xml version="1.0" encoding="UTF-8"?&gt; &lt;methodResponse&gt;   &lt;params&gt;     &lt;param&gt;       &lt;value&gt;         &lt;array&gt;&lt;data&gt;           &lt;value&gt;&lt;string&gt;system.multicall&lt;/string&gt;&lt;/value&gt;           &lt;value&gt;&lt;string&gt;system.listMethods&lt;/string&gt;&lt;/value&gt;           &lt;value&gt;&lt;string&gt;system.getCapabilities&lt;/string&gt;&lt;/value&gt;           &lt;value&gt;&lt;string&gt;demo.addTwoNumbers&lt;/string&gt;&lt;/value&gt;           &lt;value&gt;&lt;string&gt;demo.sayHello&lt;/string&gt;&lt;/value&gt;           &lt;value&gt;&lt;string&gt;pingback.extensions.getPingbacks&lt;/string&gt;&lt;/value&gt;           &lt;value&gt;&lt;string&gt;pingback.ping&lt;/string&gt;&lt;/value&gt;         &lt;/array&gt;       &lt;/value&gt;     &lt;/param&gt;   &lt;/params&gt;   &lt;value&gt;&lt;string&gt;wp.uploadFile&lt;/string&gt;&lt;/value&gt;   &lt;value&gt;&lt;string&gt;wp.getUsersBlogs&lt;/string&gt;&lt;/value&gt;   &lt;value&gt;&lt;string&gt;wp.getUsersBlogs&lt;/string&gt;&lt;/value&gt;   &lt;value&gt;&lt;string&gt;wp.getUsersBlogs&lt;/string&gt;&lt;/value&gt;</pre> |        |          |                          |
| Identified Instances (2):                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |        |          |                          |
| <ul style="list-style-type: none"><li>educationgalaxy.com/xmlrpc.php</li></ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |        |          |                          |

| ID                                                                                | Status | Severity | Subject                  |
|-----------------------------------------------------------------------------------|--------|----------|--------------------------|
| 5.1                                                                               | Open   | Medium   | xmlrpc.php [2 instances] |
| Description                                                                       |        |          |                          |
| <ul style="list-style-type: none"> <li>progresslearning.com/xmlrpc.php</li> </ul> |        |          |                          |



## 6. Sensitive Web Server Files Accessible to Users

LOW

### Overview

The identified application files are not adequately restricted to prevent unauthorized user access. These files are not protected based on application logic, and as such any remote user can access or download the file.

### Remediation Procedure

Consider either removing the identified files or using web server access control mechanisms to restrict the files from unauthorized access. For files that should be generated / served by the application, consider developing application components that can be used to render the files to users based on application-level authorization privileges.

### Issue Listing

The following items are included under this major finding:

| ID                                                                                                                                                                                                                                                                         | Status | Severity | Subject                  |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|--------------------------|
| 6.1                                                                                                                                                                                                                                                                        | Open   | Low      | phpinfo.php [1 instance] |
| <b>Description</b>                                                                                                                                                                                                                                                         |        |          |                          |
| The endpoint educationgalaxy.com has an externally accessible phpinfo.php file. This reveals internal file structure and server information, and it can potentially reveal more sensitive information in future iterations.                                                |        |          |                          |
| <b>Reproduction Request:</b>                                                                                                                                                                                                                                               |        |          |                          |
| GET /phpinfo.php HTTP/2<br>Host: educationgalaxy.com<br>[...]                                                                                                                                                                                                              |        |          |                          |
| <b>Reproduction Response:</b>                                                                                                                                                                                                                                              |        |          |                          |
| HTTP/2 200 OK<br>Date: Fri, 01 Aug 2025 17:50:20 GMT<br>Content-Type: text/html; charset=utf-8<br>Strict-Transport-Security: max-age=31536000<br>[...]<br><title>PHP 8.2.29 - phpinfo()</title><meta name="ROBOTS" content="NOINDEX,NOFOLLOW,NOARCHIVE" /></head><br>[...] |        |          |                          |
| <b>Identified Instance:</b>                                                                                                                                                                                                                                                |        |          |                          |
| ▪ educationgalaxy.com/phpinfo.php                                                                                                                                                                                                                                          |        |          |                          |



| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | Status | Severity      | Subject                 |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|---------------|-------------------------|
| 6.2                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | Open   | Informational | web.config [1 instance] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |        |               |                         |
| The web.config file for media.educationgalaxy.com is externally accessible to unauthenticated users. The file does not currently contain sensitive info, but it is best practice to not reveal it in case of future iterations containing this data.                                                                                                                                                                                                                                                                                                                     |        |               |                         |
| <b>Contents of web.config:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |        |               |                         |
| <pre>&lt;?xml version="1.0" encoding="UTF-8"?&gt; &lt;configuration&gt;   &lt;system.webServer&gt;     &lt;staticContent&gt;       &lt;clientCache cacheControlMode="UseMaxAge" cacheControlMaxAge="60.00:00:00" /&gt;     &lt;/staticContent&gt;     &lt;httpProtocol&gt;       &lt;customHeaders&gt;         &lt;add name="Access-Control-Allow-Methods" value="GET, OPTIONS" /&gt;         &lt;add name="Access-Control-Allow-Origin" value="*" /&gt;       &lt;/customHeaders&gt;     &lt;/httpProtocol&gt;   &lt;/system.webServer&gt; &lt;/configuration&gt;</pre> |        |               |                         |
| <b>Identified Instance:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |        |               |                         |
| <ul style="list-style-type: none"> <li>media.educationgalaxy.com/web.config</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |        |               |                         |

| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Status | Severity      | Subject                       |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|---------------|-------------------------------|
| 6.3                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          | Open   | Informational | Json Web Key Set [1 instance] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |        |               |                               |
| The JWKS (Json Web Key Set) for auth.progresslearning.com is externally accessible to unauthenticated users. The endpoint does not currently disclose sensitive info, but it is best practice to not reveal it as a server misconfiguration can reveal private key components.                                                                                                                                                                                                                                                                                                                               |        |               |                               |
| <b>Reproduction Request:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |        |               |                               |
| <pre>GET /.well-known/openid-configuration/jwks HTTP/2 Host: auth.progresslearning.com [...]</pre>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |        |               |                               |
| <b>Reproduction Response:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |        |               |                               |
| <pre>HTTP/2 200 OK Date: Fri, 01 Aug 2025 20:27:44 GMT Content-Type: application/json; charset=UTF-8 [...]</pre> <pre>{   "keys": [     {       "kty": "RSA",       "use": "sig",       "e": "AQAB",       "n": "7TNzdH7EcSUJq91_tx9jUAPHBRNqnmZpFyRDxzOdHBGRjSoSuGwoiSVYLvzav-knsCGgfK5bilzayP1NgxaGwr4Mdd1kR4Tvkd-I8bSpYxQyGgvpSqSoi5F_qxN5zb-meqyDK8ae6hq3J3FL06vnKAzHAB3eRGFnhxBNvX8ereTChicLeUe7BDg-_nUPuqfSoKnHXWfG1bCLDfC27sJTYf4qIsoB-sBWLtBeMAUQ7RKgwFu600y1A8ZHPYUOuZpcdcBBDxjxPYTGfrVg1vtoFstDE4z4RUqswuQkMA-ICIZKOGcXRxM4bmnDMxEra2B2hee7vK7aqQHsQWYXPQ",       "alg": "RS256"     }   ] }</pre> |        |               |                               |

| ID                                                                                                                                                   | Status | Severity      | Subject                       |
|------------------------------------------------------------------------------------------------------------------------------------------------------|--------|---------------|-------------------------------|
| 6.3                                                                                                                                                  | Open   | Informational | Json Web Key Set [1 instance] |
| Description                                                                                                                                          |        |               |                               |
| <p><b>Identified Instance:</b></p> <ul style="list-style-type: none"> <li>auth.progresslearning.com/.well-known/openid-configuration/jwks</li> </ul> |        |               |                               |



# 7. Source Map Enabled on JavaScript Deployed with Webpack

LOW

## Overview

JavaScript code used by ProgressLearning applications have been deployed with Webpack Source Map enabled. Source Map allows minified JavaScript to be completely recovered using Chrome browser DevTools. In application frameworks that heavily rely on JavaScript such as ReactJS, recovering the un-minified JavaScript source code can help an attacker identify weaknesses in the web application.

## Remediation Procedure

Webpack Source Map should be disabled when deploying applications in production environments to prevent attackers from recovering "un-minified" JavaScript source code. Webpack Source Map can be disabled when building by specifying the production flag as follows:

```
'webpack -p'
```

## Issue Listing

The following item is included under this major finding:

| ID                                                                                                                                                                                                                            | Status | Severity | Subject                                            |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|----------------------------------------------------|
| 7.1                                                                                                                                                                                                                           | Open   | Low      | JavaScript Files Deployed with Webpack [Pervasive] |
| <b>Description</b>                                                                                                                                                                                                            |        |          |                                                    |
| Multiple JavaScript files are deployed with their 'source map' enabled.                                                                                                                                                       |        |          |                                                    |
| <i>Note: This finding was previously reported as "7.1 Source Map Enabled on JavaScript Deployed with Webpack" in the report titled "AON-6433 ProgressLearning External Network Security Assessment Report February_2024".</i> |        |          |                                                    |
| <b>Reproduction Steps:</b>                                                                                                                                                                                                    |        |          |                                                    |
| 1. Download the tool Sourcemapper ( <a href="https://github.com/denandz/sourcemapper">https://github.com/denandz/sourcemapper</a> ).                                                                                          |        |          |                                                    |
| 2. Browse to <a href="https://academics.progresslearning.com/static/js/main.7c7b47ca.js">https://academics.progresslearning.com/static/js/main.7c7b47ca.js</a> .                                                              |        |          |                                                    |
| 3. In the response, find the name of the JavaScript with .map extension (e.g. sourceMappingURL=main.7c7b47ca.js.map)                                                                                                          |        |          |                                                    |
| 4. Run 'sourcemapper' script and pass the given .map URL within '-url' parameter.                                                                                                                                             |        |          |                                                    |
| <b>Reproduction Request:</b>                                                                                                                                                                                                  |        |          |                                                    |
| GET /static/js/main.7c7b47ca.js HTTP/2<br>Host: academics.progresslearning.com<br>[...]                                                                                                                                       |        |          |                                                    |
| <b>Reproduction Response:</b>                                                                                                                                                                                                 |        |          |                                                    |
| HTTP/2 200 OK<br>Date: Fri, 01 Aug 2025 17:43:01 GMT<br>Content-Type: application/javascript                                                                                                                                  |        |          |                                                    |

| ID                                                                                                                                                                                                                                                                                                                                                             | Status | Severity | Subject                                            |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|----------------------------------------------------|
| 7.1                                                                                                                                                                                                                                                                                                                                                            | Open   | Low      | JavaScript Files Deployed with Webpack [Pervasive] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                             |        |          |                                                    |
| Last-Modified: Wed, 23 Jul 2025 19:23:44 GMT<br>[...]<br>),Oae=Tae,Rae=document.getElementById("root");r.createRoot(Rae).render((0,Ch.jsx)(dt,{children:(0,Ch.jsx)(t.StrictMode,{children:(0,Ch.jsxs)(bn,{store:Oae,children:[(0,Ch.jsx)(yw.ToastContainer,{hideProgressBar:!0}),(0,Ch.jsx)(sae,{})]})})))}())();<br>//# sourceMappingURL=main.7c7b47ca.js.map |        |          |                                                    |
| <b>Reproduction Command:</b>                                                                                                                                                                                                                                                                                                                                   |        |          |                                                    |
| sourcemappper -output test -url https://academics.progresslearning.com/static/js/main.7c7b47ca.js.map                                                                                                                                                                                                                                                          |        |          |                                                    |
| For the results of the reproduction command above, please reference the following screenshot.                                                                                                                                                                                                                                                                  |        |          |                                                    |





## Screenshot for Item 7.1

The application code was reconstructed by leveraging source map of the given JavaScript file.

```
api > TS userPermission.service.ts > ...
1  import { AxiosHelper } from "../axiosConfig";
2  import APIConstant from "../utils/apiConstant";
3  import {
4    IUserPermission,
5    IUsersSearchRequest,
6  } from "../model/interface/userPermission";
7
8  export const createUserPermission = (userPermission: IUserPermission) => {
9    return AxiosHelper.axiosInstance().post(
10      `${APIConstant.CMS_USERPERMISSION}`,
11      userPermission,
12      {}
13    );
14  };
15
16  export const updateUserPermission = (userPermission: IUserPermission) => {
17    return AxiosHelper.axiosInstance().put(
18      `${APIConstant.CMS_USERPERMISSION}`,
19      userPermission,
20      {}
21    );
22  };
23
24  export const deleteUserPermission = (userId: number, permissionId: number) => {
25    return AxiosHelper.axiosInstance().delete(APIConstant.CMS_USERPERMISSION, {
26      params: {
27        userId: userId,
28        permissionId: permissionId,
29      },
30    });
31  };
32
33  export const getAllUsers = (
34    filter: IUsersSearchRequest,
35    orderByColumn: string,
36    sortBy: string,
37    pageSize: number,
38    pageNumber: number
```

## JavaScript Files Deployed with Webpack [Pervasive]



## 8. Web Server Reveals Internal Host IP Address

LOW

### Overview

The identified web server reveals its internal IP address when responding to specially crafted HTTP requests. This allows an attacker to gain more information about the internal network. IP addresses can most commonly be retrieved using one of the following techniques:

- Within the Content-Location header via a request to the root directory
- Within HTTP responses to request using a blank host HTTP header

### Remediation Procedure

#### IIS Server

To prevent IIS from disclosing the internal IP address, the "w3svc/UseHostName" value in the IIS metabase should be set to "True". For more details, reference the following resource:

- <https://techcommunity.microsoft.com/t5/iis-support-blog/removing-an-iis-server-s-ip-address-from-http-responses/ba-p/347669>

### Issue Listing

The following item is included under this major finding:

| ID                                                                                                                                                                                                                                                                                                               | Status | Severity | Subject                   |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|---------------------------|
| 8.1                                                                                                                                                                                                                                                                                                              | Open   | Low      | help.progresslearning.com |
| <b>Description</b>                                                                                                                                                                                                                                                                                               |        |          |                           |
| Requests with a blank host HTTP header sent to help.progresslearning.com can reveal the internal IP address.                                                                                                                                                                                                     |        |          |                           |
| <b>Reproduction Request:</b>                                                                                                                                                                                                                                                                                     |        |          |                           |
| GET //WNcP6Hj8.asp HTTP/1.0<br>Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1<br>Accept-Language: en<br>Connection: Keep-Alive<br>User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)<br>Pragma: no-cache<br>Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */* |        |          |                           |
| <b>Reproduction Response:</b>                                                                                                                                                                                                                                                                                    |        |          |                           |
| HTTP/1.1 301 Moved Permanently<br>Server: openresty<br>Date: Fri, 01 Aug 2025 17:16:09 GMT<br>Content-Type: text/html<br>Content-Length: 166<br><b>Location: https://10.48.1.203/WNcP6Hj8.asp</b><br>Connection: keep-alive                                                                                      |        |          |                           |



| ID                                                                                                                                                                                                                                                                  | Status | Severity | Subject                   |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|----------|---------------------------|
| 8.1                                                                                                                                                                                                                                                                 | Open   | Low      | help.progresslearning.com |
| Description                                                                                                                                                                                                                                                         |        |          |                           |
| <pre>&lt;html&gt; &lt;head&gt;&lt;title&gt;301 Moved Permanently&lt;/title&gt;&lt;/head&gt; &lt;body&gt; &lt;center&gt;&lt;h1&gt;301 Moved Permanently&lt;/h1&gt;&lt;/center&gt; &lt;hr&gt;&lt;center&gt;openresty&lt;/center&gt; &lt;/body&gt; &lt;/html&gt;</pre> |        |          |                           |



## 9. Insecure TLS/SSL Configuration

INFORMATIONAL

### Overview

The identified servers allow remote clients to establish connections using TLS/SSL protocols/cipher suites that are not recommended according to industry best practices.

#### Protocol Weaknesses:

- TLS v1.0 - This version of the protocol suffers from cryptographic weaknesses such as the BEAST attack that can allow attackers to read information sent via the "secure" connection. PCI compliance rules mandate that TLS v1.0 be disabled since June 2018 and this protocol has been deprecated in modern browsers since January 2020.
- TLS v1.1 - This version of the protocol contains some theoretical weaknesses, which have been fixed in newer versions. This protocol has been deprecated in modern browsers since January 2020.

#### Cipher Suite Weaknesses:

- 64-bit Block Ciphers - (3DES / DES / RC2 / IDEA) These ciphers provide an effective key length that is less than the recommended 128 bits.
- CBC Ciphers - CBC Ciphers have a problematic history and are no longer recommended. Where possible they should be upgraded to their more secure replacement GCM Ciphers. Note, removing CBC Ciphers will disable support for IE before 11.

### Remediation Procedure

Web servers providing sensitive data to remote clients should only allow the use of more secure TLS ciphers by remote users. Consider the following TLS/SSL configuration recommendations.

#### Protocol Recommendations:

- Disable TLS v1.0 and TLS v1.1 as soon as is feasible, enable TLS v1.2 and TLS v1.3 instead. Note that this may cause compatibility issues for users of older browsers.

#### Cipher Suite Recommendations:

- Discontinue the use of GOST R 34.11-2012, IDEA, RC2, RC4, DES and 3DES cipher suites. Enable other secure cipher suites instead.
- Consider disabling the use of CBC cipher suites. Note that this may cause compatibility issues for users of older browsers.
- Enable and prefer ephemeral ciphers that provide PFS (Perfect Forward Secrecy) - ECDHE\_RSA, ECDHE\_ECDSA, DHE\_RSA, DHE\_DSS, CECMQ1 and all TLS v1.3 ciphers. This is a requirement for the transition to TLS v1.3.
- Enable and prefer AEAD (Authenticated Encryption with Associated Data) cipher suites - CHACHA20\_POLY1305, GCM and CCM. This is a requirement for the transition to TLS v1.3.

### Issue Listing

The following items are included under this major finding:



| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Status | Severity      | Subject                                |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|---------------|----------------------------------------|
| 9.1                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Open   | Informational | TLS v1.1 Protocol Support [1 Instance] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |        |               |                                        |
| The identified application currently supports the TLS 1.1 protocol.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |        |               |                                        |
| <b>Reproduction Command:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |        |               |                                        |
| testssl.sh -p staff.progresslearning.com:443                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |        |               |                                        |
| <b>Command Output:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |        |               |                                        |
| <pre>[...] Start 2025-08-01 11:04:14          --&gt;&gt; 142.250.81.243:443 (staff.progresslearning.com) &lt;&lt;--  Further IP addresses: 2607:f8b0:4006:817::2013 rDNS (142.250.81.243): lga25s74-in-f19.1e100.net. Service detected:     HTTP  Testing protocols via sockets except NPN+ALPN  SSLv2      not offered (OK) SSLv3      not offered (OK) TLS 1      offered (deprecated) <b>TLS 1.1</b>   offered (deprecated) TLS 1.2    offered (OK) TLS 1.3    offered (OK): final NPN/SPDY   not offered ALPN/HTTP2 h2, http/1.1, grpc-exp (offered) [...]</pre> |        |               |                                        |
| <b>Identified Instance:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |        |               |                                        |
| <ul style="list-style-type: none"> <li>staff.progresslearning.com:443</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |        |               |                                        |

| ID                                                                                                                        | Status | Severity      | Subject                                |
|---------------------------------------------------------------------------------------------------------------------------|--------|---------------|----------------------------------------|
| 9.2                                                                                                                       | Open   | Informational | TLS v1.0 Protocol Support [1 Instance] |
| <b>Description</b>                                                                                                        |        |               |                                        |
| The identified application currently supports the TLS 1.0 protocol.                                                       |        |               |                                        |
| <b>Reproduction Command:</b>                                                                                              |        |               |                                        |
| testssl.sh -p staff.progresslearning.com:443                                                                              |        |               |                                        |
| <b>Command Output:</b>                                                                                                    |        |               |                                        |
| <pre>[...] Start 2025-08-01 11:04:14          --&gt;&gt; 142.250.81.243:443 (staff.progresslearning.com) &lt;&lt;--</pre> |        |               |                                        |

| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Status | Severity      | Subject                                |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|---------------|----------------------------------------|
| 9.2                                                                                                                                                                                                                                                                                                                                                                                                                                                    | Open   | Informational | TLS v1.0 Protocol Support [1 Instance] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                                                                                                                     |        |               |                                        |
| Further IP addresses: 2607:f8b0:4006:817::2013<br>rDNS (142.250.81.243): lga25s74-in-f19.1e100.net.<br>Service detected: HTTP<br><br>Testing protocols via sockets except NPN+ALPN<br><br>SSLv2 not offered (OK)<br>SSLv3 not offered (OK)<br><b>TLS 1 offered (deprecated)</b><br>TLS 1.1 offered (deprecated)<br>TLS 1.2 offered (OK)<br>TLS 1.3 offered (OK): final<br>NPN/SPDY not offered<br>ALPN/HTTP2 h2, http/1.1, grpc-exp (offered)<br>[...] |        |               |                                        |
| <b>Identified Instance:</b> <ul style="list-style-type: none"> <li>staff.progresslearning.com:443</li> </ul>                                                                                                                                                                                                                                                                                                                                           |        |               |                                        |

| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | Status | Severity      | Subject                                              |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|---------------|------------------------------------------------------|
| 9.3                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | Open   | Informational | Medium Strength Cipher Suites Supported [1 Instance] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |        |               |                                                      |
| The identified application currently supports usage of medium strength cipher suites that are more susceptible to cryptographic attacks.<br><br><b>Reproduction Command:</b><br>testssl.sh -E staff.progresslearning.com:443<br><br><b>Command Output:</b><br>[...]<br>Start 2025-08-01 11:06:34 --> 142.250.81.243:443 (staff.progresslearning.com) <--<br><br>Further IP addresses: 2607:f8b0:4006:817::2013<br>rDNS (142.250.81.243): lga25s74-in-f19.1e100.net.<br>Service detected: HTTP<br><br>Testing ciphers per protocol via OpenSSL plus sockets against the server, ordered by encryption strength<br><br>Hexcode Cipher Suite Name (OpenSSL) KeyExch. Encryption Bits Cipher Suite Name (IANA/RFC)<br>-----<br>SSLv2<br>-<br>SSLv3 |        |               |                                                      |

| ID                                                                                        | Status                       | Severity      | Subject                                              |     |                                             |  |
|-------------------------------------------------------------------------------------------|------------------------------|---------------|------------------------------------------------------|-----|---------------------------------------------|--|
| 9.3                                                                                       | Open                         | Informational | Medium Strength Cipher Suites Supported [1 Instance] |     |                                             |  |
| Description                                                                               |                              |               |                                                      |     |                                             |  |
| -                                                                                         |                              |               |                                                      |     |                                             |  |
| TLS 1                                                                                     |                              |               |                                                      |     |                                             |  |
| xc014                                                                                     | ECDHE-RSA-AES256-SHA         | ECDH          | AES                                                  | 256 | TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA          |  |
| x35                                                                                       | AES256-SHA                   | RSA           | AES                                                  | 256 | TLS_RSA_WITH_AES_256_CBC_SHA                |  |
| xc013                                                                                     | ECDHE-RSA-AES128-SHA         | ECDH          | AES                                                  | 128 | TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA          |  |
| x2f                                                                                       | AES128-SHA                   | RSA           | AES                                                  | 128 | TLS_RSA_WITH_AES_128_CBC_SHA                |  |
| x0a                                                                                       | DES-CBC3-SHA                 | RSA           | 3DES                                                 | 168 | TLS_RSA_WITH_3DES_EDE_CBC_SHA               |  |
| TLS 1.1                                                                                   |                              |               |                                                      |     |                                             |  |
| xc014                                                                                     | ECDHE-RSA-AES256-SHA         | ECDH          | AES                                                  | 256 | TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA          |  |
| x35                                                                                       | AES256-SHA                   | RSA           | AES                                                  | 256 | TLS_RSA_WITH_AES_256_CBC_SHA                |  |
| xc013                                                                                     | ECDHE-RSA-AES128-SHA         | ECDH          | AES                                                  | 128 | TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA          |  |
| x2f                                                                                       | AES128-SHA                   | RSA           | AES                                                  | 128 | TLS_RSA_WITH_AES_128_CBC_SHA                |  |
| x0a                                                                                       | DES-CBC3-SHA                 | RSA           | 3DES                                                 | 168 | TLS_RSA_WITH_3DES_EDE_CBC_SHA               |  |
| TLS 1.2                                                                                   |                              |               |                                                      |     |                                             |  |
| xc030                                                                                     | ECDHE-RSA-AES256-GCM-SHA384  | ECDH          | AESGCM                                               | 256 | TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384       |  |
| xc014                                                                                     | ECDHE-RSA-AES256-SHA         | ECDH          | AES                                                  | 256 | TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA          |  |
| xcca8                                                                                     | ECDHE-RSA-CHACHA20-POLY1305  | ECDH          | ChaCha20                                             | 256 | TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 |  |
| x9d                                                                                       | AES256-GCM-SHA384            | RSA           | AESGCM                                               | 256 | TLS_RSA_WITH_AES_256_GCM_SHA384             |  |
| x35                                                                                       | AES256-SHA                   | RSA           | AES                                                  | 256 | TLS_RSA_WITH_AES_256_CBC_SHA                |  |
| xc02f                                                                                     | ECDHE-RSA-AES128-GCM-SHA256  | ECDH          | AESGCM                                               | 128 | TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256       |  |
| xc013                                                                                     | ECDHE-RSA-AES128-SHA         | ECDH          | AES                                                  | 128 | TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA          |  |
| x9c                                                                                       | AES128-GCM-SHA256            | RSA           | AESGCM                                               | 128 | TLS_RSA_WITH_AES_128_GCM_SHA256             |  |
| x2f                                                                                       | AES128-SHA                   | RSA           | AES                                                  | 128 | TLS_RSA_WITH_AES_128_CBC_SHA                |  |
| x0a                                                                                       | DES-CBC3-SHA                 | RSA           | 3DES                                                 | 168 | TLS_RSA_WITH_3DES_EDE_CBC_SHA               |  |
| TLS 1.3                                                                                   |                              |               |                                                      |     |                                             |  |
| x1302                                                                                     | TLS_AES_256_GCM_SHA384       |               | AESGCM                                               | 256 | TLS_AES_256_GCM_SHA384                      |  |
| x1303                                                                                     | TLS_CHACHA20_POLY1305_SHA256 |               | ChaCha20                                             | 256 | TLS_CHACHA20_POLY1305_SHA256                |  |
| x1301                                                                                     | TLS_AES_128_GCM_SHA256       |               | AESGCM                                               | 128 | TLS_AES_128_GCM_SHA256                      |  |
| Done 2025-08-01 11:07:02 [0030s] --> 142.250.81.243:443 (staff.progresslearning.com) <<-- |                              |               |                                                      |     |                                             |  |
| Identified Instance:                                                                      |                              |               |                                                      |     |                                             |  |
| ▪ staff.progresslearning.com:443 ['DES-CBC3-SHA']                                         |                              |               |                                                      |     |                                             |  |



## 10. HTTP Security Response Header Misconfiguration

INFORMATIONAL

### Overview

The application does not set securely configured HTTP Security Response Headers, increasing the risk of end-user exposure to malicious content injection, including Cross-Site Scripting (XSS) attacks, XSS through MIME-Sniffing, Adversary-in-the-Middle (AitM) attacks due to lack of HTTPS enforcement, and Clickjacking attacks caused by a permissive framing policy.

HTTP Security Response Headers provide the option for an application to enforce security at the browser level to protect end-users from malicious attacks. For a description and purpose of each header, reference the recommendation listing below. In this case, the Strict-Transport-Security header was found to be missing.

### Remediation Procedure

The application server should set the following headers to specify the security options that any compatible browser must adhere to:

Strict-Transport-Security - HTTP Strict Transport Security (HSTS) is a method of informing browsers that the site should never be loaded over an unencrypted HTTP connection. By enforcing the use of the "Strict-Transport-Security" header, any HTTP requests should be converted to use HTTPS. As a minimum, the header should be set as follows:

```
Strict-Transport-Security: max-age=31536000; includeSubDomains
```

The above "Strict-Transport-Security" header instructs the browser to not attempt an HTTP connection to the domain or any subdomains for 31536000 seconds (or 1 year). Note, however, that this does not protect the initial connection or connection following the expiry of the "max-age" directive. In order to protect said connections, the use of the "preload" directive and submission for hardcoding into major browsers (<https://hstspreload.org>) is recommended for external sites. Where preloaded HSTS is not possible, such as for internal sites, consider disabling HTTP support on the web server.

For more information regarding the HSTS and the "Strict-Transport-Security" header, reference the following resources:

- <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security>
- [https://cheatsheetseries.owasp.org/cheatsheets/HTTP\\_Strict\\_Transport\\_Security\\_Cheat\\_Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html)
- <https://scotthelme.co.uk/hsts-preloading/>
- <https://datatracker.ietf.org/doc/html/rfc6797>

### Issue Listing

The following item is included under this major finding:

| ID                                                                                                                                               | Status | Severity      | Subject                                               |
|--------------------------------------------------------------------------------------------------------------------------------------------------|--------|---------------|-------------------------------------------------------|
| 10.1                                                                                                                                             | Open   | Informational | HSTS Missing From HTTPS Server Response [2 Instances] |
| Description                                                                                                                                      |        |               |                                                       |
| The identified web servers communicate over TLS/SSL and do not enforce HSTS by sending the 'Strict-Transport-Security' header in their response. |        |               |                                                       |



| ID                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           | Status | Severity      | Subject                                               |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|---------------|-------------------------------------------------------|
| 10.1                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | Open   | Informational | HSTS Missing From HTTPS Server Response [2 Instances] |
| <b>Description</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |        |               |                                                       |
| <b>Reproduction Command:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |        |               |                                                       |
| <pre>wget https://content.pendo.progresslearning.com:443/ --no-check-certificate -S</pre>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |        |               |                                                       |
| <b>Command Output:</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |        |               |                                                       |
| <pre>--2025-08-01 08:05:21-- https://content.pendo.progresslearning.com/ Resolving content.pendo.progresslearning.com (content.pendo.progresslearning.com)... 18.239.168.31, 18.239.168.42, 18.239.168.78, ... Connecting to content.pendo.progresslearning.com (content.pendo.progresslearning.com) 18.239.168.31 :443... connected. HTTP request sent, awaiting response... HTTP/1.1 403 Forbidden Content-Type: application/xml; charset=UTF-8 Content-Length: 300 Connection: keep-alive X-GUploader-UploadID: ABgVH88M052MS3eL7gLvH9BCsNvzbJXyDEyj-_T_K-AS3dmyDUjU8HbzCy2mhboAYQTfRthWuz7wfInFuYKSA Access-Control-Allow-Origin: * Access-Control-Expose-Headers: * Date: Fri, 01 Aug 2025 12:05:21 GMT Expires: Fri, 01 Aug 2025 12:05:21 GMT Cache-Control: private, max-age=0 Server: UploadServer X-Cache: Error from cloudfront Via: 1.1 533033bf81caa91a19110118c7429b94.cloudfront.net (CloudFront) X-Amz-Cf-Pop: BOS50-P3 X-Amz-Cf-Id: R0yVigKT_hqGxxq8yPt1SKaFjBnmCmBJvckMKXsgLHAVwnkZ3aJ59A== 2025-08-01 08:05:21 ERROR 403: Forbidden.</pre> |        |               |                                                       |
| <b>Identified Instances (2):</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |        |               |                                                       |
| <ul style="list-style-type: none"> <li>content.pendo.progresslearning.com:443</li> <li>help.progresslearning.com:443</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |        |               |                                                       |

# 11. Potentially Unnecessary Network Services Exposed Remotely

INFORMATIONAL

## Overview

Potentially unnecessary network services are exposed remotely. Running unnecessary network services and processes increases the attack surface of a system and subsequently its risk of successful compromise.

## Remediation Procedure

Review perimeter firewall rules to ensure that only access to necessary services are permitted from un-trusted networks (such as the Internet). Additionally, review running network services and processes and disable those not required for normal business operations.

## Issue Listing

The following item is included under this major finding:

| ID                                                                                                                                                                                                                                                                                                                                                                                                                     | Status | Severity      | Subject            |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|---------------|--------------------|
| 11.1                                                                                                                                                                                                                                                                                                                                                                                                                   | Open   | Informational | SMTP [2 instances] |
| Description                                                                                                                                                                                                                                                                                                                                                                                                            |        |               |                    |
| The SMTP service is exposed the internet. The severity of this finding has been lowered as authentication to the server is not allowed, yet it is required to send emails.                                                                                                                                                                                                                                             |        |               |                    |
| Reproduction Command:                                                                                                                                                                                                                                                                                                                                                                                                  |        |               |                    |
| telnet smart.progresslearning.com 25                                                                                                                                                                                                                                                                                                                                                                                   |        |               |                    |
| Reproduction Response:                                                                                                                                                                                                                                                                                                                                                                                                 |        |               |                    |
| Trying 51.81.11.12...<br>Connected to smart.progresslearning.com.<br>Escape character is '^]'.<br>220 vin1-relay.sendergen.com ESMTP<br>[...]<br>HELO<br>501 Syntax: HELO hostname<br>AUTH NTLM 334<br>503 5.5.1 Error: authentication not enabled<br>[...]<br>MAIL FROM:<sales@progresslearning.com><br>250 2.1.0 Ok<br>RCPT TO:<test@gds.com><br>554 5.7.1 <test@gds.com>: Recipient address rejected: Access denied |        |               |                    |
| Identified Instances:                                                                                                                                                                                                                                                                                                                                                                                                  |        |               |                    |
| <ul style="list-style-type: none"><li>51.81.11.12:25</li><li>51.81.11.12:587</li></ul>                                                                                                                                                                                                                                                                                                                                 |        |               |                    |

# Exhibit A: Post-Assessment Clean-Up

During the course of the assessment, Stroz Friedberg emulated tactics, techniques, and procedures (TTPs) commonly used by threat actors to assess the security of the network environment. This may have resulted in both intentional and unintentional changes to the environment. This section outlines the most relevant and notable activities to aid ProgressLearning's internal teams during their post-assessment clean-up procedures.

*Note: This section is not meant to be exhaustive. It is strongly recommended that ProgressLearning conduct a comprehensive review of all systems and their associated configurations post-assessment to aid in clean-up exercises.*

Below is a compilation of notable testing activities that should be reviewed.

- Any access control changes made to the testing environment to grant Stroz Friedberg access – such as modifications to the firewall, VPN, IDS/IPS, or WAF configurations – should be reverted.



# Appendix A: Stroz Friedberg's Penetration Testing Services

Stroz Friedberg offers a full suite of advanced penetration testing services simulating real-world attack scenarios to identify vulnerabilities.



## Application Testing

Evaluate web, API, and thick clients for application specific vulnerabilities, such as those outlined in the OWASP Top Ten List.



## Secure Code Analysis

Source code analysis-driven review of web, mobile, and thick client applications. This is commonly coupled with Application Testing for a more comprehensive hybrid approach.



## Mobile Application Testing

Determine whether iOS/Android applications are affected by mobile application specific vulnerabilities such as those outlined in the OWASP Mobile Top Ten.



## Network Testing

Evaluate external and internal networks, identify vulnerable services, missing security controls, and perform controlled proof-of-concept exploitation.



## Cloud Security Config Review

Identify vulnerable resources, misconfigured environments, and missing security controls within AWS, GCP, OCI, and Microsoft Azure.



## Wireless Network Testing

Evaluate the security of wireless networks to include authentication methods, encryption protocols, and access point configuration.



## Social Engineering Testing

Gauge employee susceptibility through real-life phishing, vishing, and physical campaigns targeting specific groups of employees.



## Compromise Simulation

As an authenticated insider, simulate malware or a targeted attack, attempt to breach security controls, and gain access to restricted data and non-authorized internal systems.



## Red Team Testing

Simulate the Tactics, Techniques, and Procedures (TTPs) of advanced threat actors. Test the effectiveness of monitoring, detection, and response controls.



## Product Security Testing

Full-stack evaluation of the security of hardware, firmware, software, and application components of a product. Includes comprehensive reviews of secure boot processes, firmware updates, and hardware communication protocols.



**STROZ FRIEDBERG**

A LevelBlue Company

ProgressLearning, AON-7218-1 | 8/17/25  
Proprietary & Confidential

# Appendix B: Stroz Friedberg's Cyber Defense Training Platform

Stroz Friedberg's Cyber Defense Training platform is an annual subscription-based service that teaches industry-leading **hands-on** secure coding practices and server hardening techniques via on-demand training to Developers and DevOps engineers. The Cyber Defense training platform can help organizations save time and money by proactively helping to reduce and potentially prevent vulnerabilities and misconfigurations. Additionally, the platform measures secure coding competency through real-world exercises, tournaments, and powerful analytics.

## What's Included:



**Adaptive Learning** — Individualized learning paths, real-time feedback and content tailored to the needs of each individual learner.



**Real-time Metrics** — Metrics dashboard measures effectiveness in real-time and highlights areas of improvement at individual, team, and organizational levels to measure competency, risks, and remedial actions.



**Defensive Training** — Hands-on lessons-learned through real-world vulnerabilities that have led to recent security breaches.



**Tournaments** — Learn together through friendly and fun competition. Tournaments engage your teams and promote learning in a fun manner.



**Real Training Grounds** — Exercises run in real desktop development environments, created in seconds and accessed through the web browser. Participants are trained with the same integrated development environment (IDE) and tools being used in the workplace.



**SDLC Integration** — Embed our security training as part of your software development lifecycle using our application programming interface (APIs), and create custom exercises using the software development kit (SDK).

## Current Training Modules:

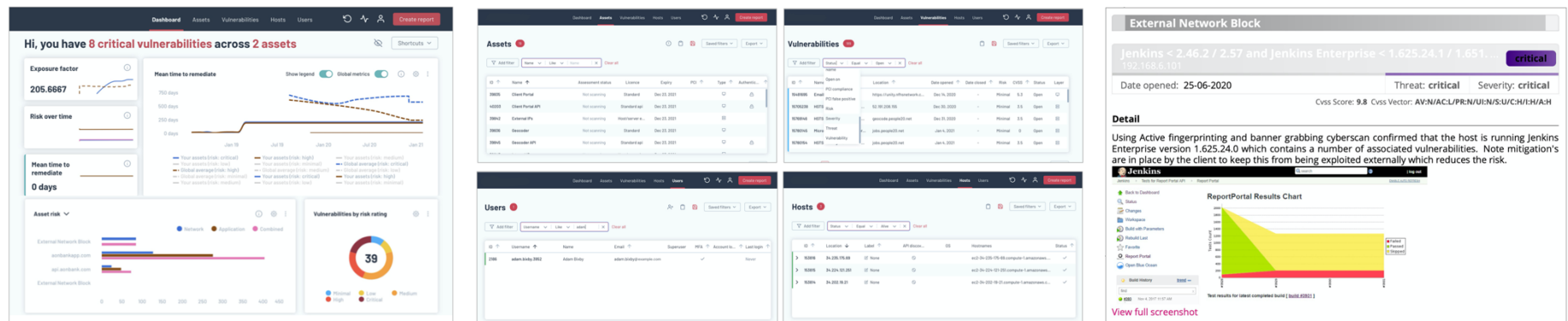


**STROZ FRIEDBERG**  
A LevelBlue Company

ProgressLearning, AON-7218-1 | 8/17/25  
Proprietary & Confidential

# Appendix C: Vulnerability Management with CyberScan

CyberScan is an enterprise-grade fullstack vulnerability assessment solution that gives organizations the tools needed to help control and manage IT security risk. Delivered as a cloud based managed service, CyberScan provides a combination of technology and human expertise to supply on-demand, verified security risks. This can reduce the need for internal resources to manage the solution, and allows organizations to immediately focus on addressing and remediating identified risks.



# About Stroz Friedberg

Although we endeavor to provide accurate and timely information and use sources we consider to be reliable, Stroz Friedberg does not make any representation as to the accuracy of information received from third party sources and is unable to accept liability for any loss incurred by any party relying on it nor does Stroz Friedberg guarantee that such information is accurate as of the date it is received or that it will continue to be accurate in the future.

The information contained in this document should not be considered or construed as legal or tax advice and is for general guidance only. Accordingly, the information contained herein is provided with the understanding that Stroz Friedberg, its employees and related entities are not engaged in rendering legal or tax advice. As such, this should not be used as a substitute for consultation with legal and tax counsel or other professional advisors that may be appropriate given the information.

[strozfriedberg.com](http://strozfriedberg.com)



**STROZ FRIEDBERG**

A LevelBlue Company

ProgressLearning, AON-7218-1 | 8/17/25  
*Proprietary & Confidential*